

Mapeo Detallado Pregunta ↔ Requisito Normativo

Nota: Las referencias a NIST SP 800-171 son orientativas, agrupadas por familias.
ENS/NIS2/DORA se citan a nivel de artículo o dominio de control cuando aplica.

Bloque	Nº Pregunta	Texto abreviado de la pregunta	CMMC / Familia	NIST SP 800-171 / 172	ENS / NIS2 / DORA (referencia genérica)
1. Gobernanza	1.1	Estrategia formal de ciberseguridad	Governance / Risk Management	RA-1, PM-1, PM-9	ENS (Org.1, Org.2), NIS2 (Art. 21 – medidas de gestión de riesgos)
1. Gobernanza	1.2	Frecuencia de reporte al órgano de gobierno	Governance	PM-3, PM-8	ENS (Org.3), NIS2 (gobernanza de la ciberseguridad)
1. Gobernanza	1.3	Existencia de CISO / responsable designado	Governance / Personnel Security	PM-2, PS-1	ENS (Org.1, Org.4), NIS2 (responsables de ciberseguridad)
1. Gobernanza	1.4	Integración del riesgo ciber en mapa de riesgos	Risk Management	RA-2, RA-3	ENS (Org.2, Op.1), NIS2 (gestión de riesgos, Art. 21)
1. Gobernanza	1.5	Coordinación con cumplimiento normativo	Governance / Compliance	PM-1, CA-1	ENS (Org.5), NIS2 (supervisión y cumplimiento)
2. Marcos	2.1	Marcos de referencia utilizados	Governance	PM-1	ENS (Org.1), NIS2 (alineación con normas internacionale s)
2. Marcos	2.2	Uso de CMMC como referencia	Governance	PM-1	Sin referencia específica; alineado con buenas prácticas
2. Marcos	2.3	Nivel CMMC objetivo	Governance / Planning	PM-1, PM-3	ENS (Org.1), NIS2 (estrategia y planificación)

2. Marcos	2.4	Mapeo ENS/NIS2/DO RA → CMMC/NIST	Governance / Risk	CA-2, PM-1	ENS (Org.1, Org.5), NIS2 (coordinación nacional)
3. Activos	3.1	Inventario de activos	Asset Management	CM-8	ENS (Op.5 – inventario de activos), NIS2 (medidas técnicas)
3. Activos	3.2	Plazo de aplicación de parches críticos	Configuration Management	CM-6, SI-2	ENS (Op.8), NIS2 (medidas técnicas y operativas)
3. Activos	3.3	Frecuencia de análisis de vulnerabilidad es	Risk / Vulnerability Management	RA-5	ENS (Op.8, Op.12), NIS2 (gestión de vulnerabilidad es)
3. Activos	3.4	Métricas de vulnerabilidad es	Risk Management	RA-5, CA-7	ENS (Op.8), NIS2 (monitoreo y pruebas)
4. Accesos	4.1	Gestión de cuentas y privilegios	Access Control	AC-2, AC-6	ENS (Op.4), NIS2 (control de acceso)
4. Accesos	4.2	Uso de MFA en cuentas críticas	Access Control / Identification & Authenticatio n	IA-2, IA-5	ENS (Op.2, Op.4), NIS2 (autenticación robusta)
4. Accesos	4.3	Protección de accesos remotos	Access Control / System and Communicatio ns Protection	AC-17, SC-7	ENS (Op.3, Op.4), NIS2 (medidas técnicas)
5. Datos	5.1	Clasificación de información sensible	Access Control / Media Protection	MP-3, AC-3	ENS (Op.1, Op.7), RGPD (art. 32), NIS2 (protección de información)
5. Datos	5.2	Cifrado en reposo	Media Protection	MP-5, SC-28	ENS (Op.7), NIS2 (seguridad de redes y sistemas)

5. Datos	5.3	Cifrado en tránsito	System and Communications Protection	SC-8, SC-13	ENS (Op.7, Pr.1), NIS2 (medidas técnicas)
5. Datos	5.4	Controles DLP / exfiltración	System and Communications Protection	SC-7, SI-4	ENS (Op.7, Op.8), NIS2 (protección de datos)
6. Monitorización	6.1	Grado de monitorización (SIEM/SOC)	Audit and Accountability / Incident Response	AU-6, IR-5	ENS (Op.8, Op.9), NIS2 (detección de incidentes)
6. Monitorización	6.2	Métricas MTTD/MTTR	Incident Response	IR-5, CA-7	ENS (Op.9), NIS2 (resiliencia y respuesta)
6. Monitorización	6.3	Plan de respuesta a incidentes	Incident Response	IR-1, IR-2	ENS (Op.9), NIS2 (gestión de incidentes)
6. Monitorización	6.4	Ejercicios y simulacros	Incident Response / Contingency Planning	IR-3, CP-4	ENS (Op.9, Op.10), NIS2 (pruebas periódicas)
7. Formación	7.1	Formación general anual	Awareness and Training	AT-2	ENS (Org.2), NIS2 (formación del personal)
7. Formación	7.2	Formación específica por rol	Awareness and Training	AT-3	ENS (Org.2), NIS2 (formación especializada)
7. Formación	7.3	Simulaciones de phishing	Awareness and Training	AT-2, AT-4	ENS (Org.2, Op.9), NIS2 (concienciación)
7. Formación	7.4	Cultura de reporte	Awareness and Training	AT-2	ENS (Org.2), NIS2 (gestión de incidentes)
8. Proveedores	8.1	Identificación de proveedores críticos	Risk Management / Supply Chain	RA-3, SR-2	ENS (Org.3, Op.11), NIS2 (cadena de suministro)
8. Proveedores	8.2	Requisitos de seguridad en contratos	Supply Chain Risk Management	SR-3, SR-5	ENS (Org.3, Op.11), NIS2 (relaciones con terceros)

8. Proveedores	8.3	Evaluación periódica de proveedores	Supply Chain Risk Management	SR-6	ENS (Org.3, Op.11), NIS2 (gestión de proveedores)
9. Documentación	9.1	System Security Plan (SSP)	Planning / Documentation	PL-2, PL-8	ENS (Org.1, Org.5), NIS2 (documentación de medidas)
9. Documentación	9.2	POA&M y seguimiento	Plan of Action and Milestones	CA-5, PM-4	ENS (Org.5), NIS2 (gestión de medidas correctivas)
9. Documentación	9.3	Evidencias de cumplimiento	Audit and Accountability	AU-3, AU-6	ENS (Org.5, Op.9), NIS2 (demostración de cumplimiento)
10. Métricas	10.1	Definición de KPIs/KRIs	Governance / Risk Management	PM-1, CA-7	ENS (Org.2, Org.5), NIS2 (gestión basada en riesgos)
10. Métricas	10.2	Frecuencia de reporte de métricas	Governance	PM-3, CA-7	ENS (Org.3), NIS2 (supervisión)
10. Métricas	10.3	Índices de madurez internos	Governance / Risk	PM-4, CA-7	ENS (Org.2), NIS2 (evaluación continua)
11. Inversión	11.1	Evolución de la inversión	Governance / Risk	PM-3, RA-3	ENS (Org.2), NIS2 (proporcionalidad de medidas)
11. Inversión	11.2	Evaluación de ROI	Governance / Risk	RA-3	ENS (Org.2), NIS2 (eficiencia económica)
11. Inversión	11.3	Priorización de mejoras	Risk Management	RA-3, PM-4	ENS (Org.2), NIS2 (gestión del riesgo)
12. Percepción	12.1	Autopercepción de madurez	Governance	PM-1	Sin referencia directa, útil para contraste interno

12. Percepción	12.2	Ambición a 3 años	Governance / Planning	PM-3	ENS (Org.1), NIS2 (planificación estratégica)
12. Percepción	12.3	Comentarios abiertos	—	—	—

Este mapeo puede ampliarse con referencias más finas (artículos concretos de NIS2, medidas ENS por categoría de sistema, etc.) según el sector.